Data Protection & Client Confidentiality Policy

Document No. AUR-SAF-03 · Version 0.2 (Draft) · Owner: General Manager · Effective: [Date]

> Draft for internal use. To be reviewed by a UAE-qualified legal adviser once the trade license is issued.

1. Purpose and scope

Guests trust us with how they feel, what they are recovering from and, sometimes, their medical history. This policy explains how The Aura Reset Center collects, uses, protects and shares personal data, and how every team member keeps guest information confidential.

It applies to all personal data processed by [Registered Company Name] ([Trade License No.]) for the Dubai studio in Jumeirah 1, in any format: paper, digital, audio and video. It applies to employees, Hosts, Healers, contractors and anyone with access to our systems.

2. Legal framework

- **UAE:** Federal Decree-Law No. 45 of 2021 on the Protection of Personal Data (PDPL) and its executive regulations as issued. No medical treatments are offered at launch, so no clinical records are created. Wellness intake data, and any information shared with the [Medical Director named on the licence] for escalation, is handled in line with UAE health data laws and DHA requirements where applicable. If clinical services (for example IV Nutrient Therapy) are added in future, subject to DHA licensing, this policy would be updated for clinical record keeping.
- **United States:** our location at 1936 East Deere Avenue, Suite 120, Santa Ana, California handles its own guest data under applicable US federal and California law. Where a member uses both locations ("your membership travels with you"), data shared between them is treated as an international transfer (Section 11).

[Registered Company Name] is the controller for Dubai guest data. Data Protection Lead: [Name / role, e.g. General Manager], [Email].

3. Principles

We process personal data:

1. Lawfully, fairly and transparently.
2. Only for clear, stated purposes.
3. Limited to what we actually need.
4. Accurately, and corrected when wrong.
5. Kept no longer than needed.

6. Securely, protected against loss, misuse and unauthorised access.
7. With accountability: we can show how we comply.

4. What we collect and why

Data category	Examples	Purpose	Lawful basis
Identity and contact	Name, phone, WhatsApp, email, date of birth, emergency contact	Bookings (online and WhatsApp), confirmations, safety	Contract; legitimate interest (safety)
Health and wellness intake (sensitive)	Medical conditions, medication, pregnancy, contraindications, goals (e.g. "Sleep deeper", "Calm the stress"), how you arrived feeling	Safe screening for each modality; building your protocol	Explicit consent; necessary for health services where applicable
Healer consultation notes (sensitive)	Core concern identified at the first visit, personalised package or programme, energy-healing and nervous-system notes	Designing and reviewing the guest's programme	Explicit consent
Consent and waiver forms	Signed consents per modality, waivers	Evidence of informed consent	Legal obligation; contract
Booking and visit history	Modalities and sessions booked (including Sound Healing and Guided Breathwork), times, session notes, host notes, combinations suggested	Running the service; protocol reviews for Elevate members	Contract
Membership and payment	Plan (Single Reset, Restore, Elevate, founding member), packages, billing dates, pauses, card or Apple Pay token, cash receipts, retail purchases, invoices	Billing, membership management, tax records	Contract; legal obligation
CCTV	Images in reception, entrances and corridors (never in changing rooms, showers, treatment rooms or consultation rooms)	Safety and security	Legitimate interest; legal obligation where required
Device session data	Settings and readings from Elevé devices (e.g. cryo thermal-vision monitoring, HBOT pressure log)	Safety and quality	Legitimate interest; legal obligation

Data category	Examples	Purpose	Lawful basis
Marketing preferences	Opt-ins, founding member list sign-up, launch event RSVP	Sending news and offers	Consent
Website, social and ad leads	Enquiries and lead forms from paid ad campaigns (Meta / Instagram / Google), [Website], [Instagram] and [WhatsApp]	Responding quickly to enquiries	Legitimate interest; consent

We accept Apple Pay, card and cash (Tabby to follow later). We do not take card numbers on paper. Card and Apple Pay payments are processed by [Payment provider]; we store only a token and the last four digits. Cash sales are recorded against the booking with a receipt.

5. Consent

- Health data is collected only with the guest's explicit, informed consent, given on the intake form before the first session.
- Consent is specific (health screening is separate from marketing), recorded with date and time, and can be withdrawn at any time. Withdrawing consent for health screening means we cannot safely provide that modality.
- Guests under 18: [Minimum age policy]; a parent or guardian gives consent.
- Marketing consent is never a condition of booking.

6. Retention

Record	Retention period
Intake and health screening forms	[___ years after last visit]
Healer consultation notes	[___ years after last visit]
Signed consents and waivers	[___ years after last visit]
Booking and visit history	[___ years after last visit]
Payment and tax records	[Per UAE tax law, ___ years]
CCTV footage	[___ days], unless needed for an incident
Incident reports	[___ years]
Marketing list	Until consent is withdrawn or [___ years] of inactivity
Founding member waiting list (if not converted)	[___ months] after launch

At the end of the period, data is securely deleted or anonymised. Paper is cross-cut shredded by [Shredding contractor].

7. Access control and security

- Access is on a need-to-know basis by role:

Role	Booking and contact	Wellness intake	Healer consultation notes	Payment	CCTV
Hosts	Yes	Yes (for their guest)	Package summary only	Status only	No
Healers	Yes	Yes	Yes (for their guest)	No	No
Duty Manager	Yes	Yes	No	Status only	View
General Manager	Yes	Yes	On request with reason	Yes	Yes
Founder & CEO, CEO	Reports	On request with reason	No	Yes	On request

- Unique logins and strong passwords; multi-factor authentication on the booking system [Booking system — to be chosen] and email.
- Screens lock automatically; reception screens face away from guests.
- Paper forms are kept in a locked cabinet and scanned into the guest record within [24 hours], then shredded or archived securely.
- Devices are encrypted. Personal phones are not used to store guest data or photos.
- Supplier contracts include data protection terms. Elevé Health has access only to device data needed for service and support.
- Access rights are removed on the day a team member leaves.

8. Staff confidentiality

Every team member signs a confidentiality agreement before starting. In practice:

- Never discuss a guest's health, visit or conversation outside the studio, on social media, or with other guests.
- Never confirm whether someone is a guest. Many guests are well known; discretion is part of our service.
- Do not photograph or film guests. Social content with a guest requires their written consent.
- Speak quietly about guest details in shared areas. Use names only, not conditions, at reception.
- Share with colleagues only what they need to serve the guest safely.
- Breach of confidentiality is a disciplinary matter under our HR policies and UAE Federal Decree-Law No. 33 of 2021.

9. Data subject rights

Under the PDPL, guests may ask to:

- be informed how their data is used
- access a copy of their data
- correct inaccurate data
- delete their data (subject to legal retention, e.g. tax records)
- restrict or object to processing
- move their data to another provider (portability)
- withdraw consent at any time
- object to direct marketing

How we respond:

1. Requests come by [Email], in person or by [WhatsApp]. Any team member who receives one passes it to the Data Protection Lead the same day.
2. We verify the person's identity.
3. We respond within [30] days or the timeframe set by the PDPL regulations.
4. We log each request: date, type, action taken, response date.
5. No fee, unless the request is manifestly excessive.

10. Data breach response

A breach is any loss, theft, unauthorised access or disclosure of personal data, for example a misdirected email, a lost tablet, or intake forms left at reception.

1. **Contain:** the person who finds it reports it at once to the Duty Manager and Data Protection Lead. Stop the cause (recall the email, change passwords, lock the account).
2. **Assess:** within [24 hours], the Data Protection Lead assesses what data, how many guests, and the risk to them. Health data breaches are treated as high risk.
3. **Notify:** where required by the PDPL, notify the UAE Data Office within the required timeframe, and notify affected guests without delay where the breach may harm them. Escalate to the General Manager, Founder & CEO and CEO. Breaches involving health data are also reported to the [Medical Director named on the licence] and, where required, DHA.
4. **Record:** log every breach, even minor ones, with facts, effects and actions.
5. **Learn:** review the cause and update controls and training.

11. International transfers

Personal data may leave the UAE in these cases:

- **US location:** where a member uses the Santa Ana location, their membership and relevant booking data are shared with the US team. Health intake data is shared only with the guest's consent.
- **Booking software provider:** [Booking software provider] may host data on servers in [Country / region].
- **Advertising platforms:** ad-campaign lead data passes through Meta and Google, which may process it outside the UAE; only the data needed to respond is kept.
- **Payment, email and cloud providers:** [Providers and hosting locations].
- **Elevé Health:** device service data may be accessed by Elevé technical support, including from the US.

Transfers happen only where the PDPL allows: to a country with adequate protection, under contractual safeguards, or with the guest's explicit consent. We keep a register of transfers and suppliers.

12. CCTV

- Signs at entrances explain that CCTV is in use, why, and who to contact.
- Cameras cover reception, entrances, corridors and back-of-house only.
- Footage is viewed only by the General Manager or Duty Manager for a stated reason, and shared only with police or authorities on lawful request.
- Retention: [___ days], then automatic overwrite.

13. Marketing

- We send marketing (newsletters, launch event invitations, membership news, founding member updates) only to people who have opted in.
- Opt-in is separate for each channel: email, WhatsApp, SMS.
- Every message includes an easy way to opt out. Opt-outs are actioned within [___ days].
- Booking confirmations, calendar invites and service messages are not marketing.
- We never sell or rent guest data.
- Testimonials and photos of guests require separate written consent.

14. Records and review

The Data Protection Lead keeps a record of processing activities, the supplier register, consent records, the rights request log and the breach log. This policy is reviewed every [12] months and when the PDPL executive regulations or our systems change.

Name	Signature	Date
General Manager _____	_____	_____
Founder & CEO _____	_____	_____

STAFF ACKNOWLEDGEMENT

I have read and understood this policy and agree to keep guest information confidential during and after my employment.

Name	Signature	Date
_____	_____	_____